

Controles Gerais de Auditoria de Sistemas

segunda-feira, 13 de abril de 2026 09:48

Controles de software de sistema, controles de acesso, controles de desenvolvimento e alteração de softwares em aplicativo

Em um contexto de auditoria de segurança da informação, há diferentes tipos de controles que são implementados para garantir a integridade, confidencialidade e disponibilidade dos dados. Esses controles devem ser avaliados nas auditorias para garantir que as práticas de segurança estejam implementadas de maneira eficaz.

Quando falamos de **controles de software de sistema**, dizemos respeito às medidas de segurança implementadas no nível do sistema operacional para garantir a integridade, confidencialidade e disponibilidade do ambiente de computação. Para esses controles, em uma auditoria, podemos fazer:

- Verificação de atualizações regulares do sistema operacional.
- Avaliação das configurações de segurança, como firewalls e políticas de senhas.
- Revisão de logs e eventos do sistema para identificar atividades suspeitas.
- Verificação dos controles de acesso físico a servidores e data centers.

Quando nos referimos aos **controles de acesso**, que são os controles que gerenciam quem tem permissão para acessar determinados recursos ou informações em um sistema, em uma auditoria, podemos fazer:

- Revisão dos processos de autenticação de usuários (senhas, tokens, biometria).
- Avaliação das autorizações de acesso com base em funções (RBAC).
- Verificação dos controles de acesso físico a instalações críticas.

Quando falamos de **controles de desenvolvimento e alteração de software aplicativo**, nos referimos às práticas durante o ciclo de vida do desenvolvimento de software para garantir a segurança do código e dos aplicativos. Para esses controles, em uma auditoria podemos fazer:

- Revisão de políticas e procedimentos de segurança durante o desenvolvimento de software.
- Avaliação das práticas de revisão de código para identificar vulnerabilidades.
- Verificação dos testes de segurança, como testes de penetração e varreduras de vulnerabilidades.
- Análise das políticas de gerenciamento de configuração para garantir a integridade do software.

Durante uma auditoria, os auditores avaliam se esses controles estão alinhados com as melhores práticas de segurança da informação e se estão sendo implementados de maneira consistente. Isso ajuda a garantir que a organização esteja tomando medidas adequadas para proteger seus sistemas e dados contra ameaças de segurança. Além disso, a conformidade às regulamentações e padrões relevantes também é verificada durante o processo de auditoria.

Controles físicos e lógicos

Para Imoniana (2016), uma função de segurança bem controlada tem mecanismos para restringir o acesso físico aos recursos de computação, programas para restringir o acesso lógico a esses recursos e procedimentos estabelecidos para monitorar e garantir a segurança de informações. Perda de hardware ou meios físicos de arquivo de dados, alterações não autorizadas de dados ou programas, ou controles programados ineficientes, podem indicar ineficiência no controle da segurança de acessos lógicos.

O NIST Cybersecurity Framework (2020) tem uma família de controles de segurança para o controle de acesso. Esses controles são um dos principais alvos de avaliações em auditorias e envolvem controles relacionados à identificação, autenticação e autorização, como pode ser visto no Quadro 1:

Política e procedimentos	Controle de acesso para dispositivos móveis
Gerenciamento de contas	Atributos de segurança e privacidade
Aplicação do acesso	Acesso remoto
Aplicação do fluxo de informação	Acesso sem fio
Separação de deveres	Controle de acesso para dispositivos móveis
Menor privilégio	Uso de sistemas externos
Tentativas de acesso sem sucesso	Compartilhamento de informações
Notificação de uso do sistema	Conteúdo acessível publicamente
Notificação do acesso anterior	Proteção contra mineração de dados
Controle de sessões concorrentes	Decisões de controle de acesso
Bloqueio de dispositivo	Monitor de referência
Término de sessão	Ações permitidas sem identificação ou autenticação
Política e procedimentos	Atributos de segurança e privacidade
Gerenciamento de contas	Acesso remoto
Aplicação do acesso	Acesso sem fio
Aplicação do fluxo de informação	Cercas e Barreiras
Monitoramento visual	...

Quadro 1 | Controles de acesso. Fonte: adaptado de Cybersecurity Framework (2020).

Os **controles físicos** são as medidas tangíveis e visíveis implementadas para proteger os ativos de informação contra acessos não autorizados, danos ou interferências físicas. Podemos citar:

- Cercas e barreiras com limitação física do acesso a instalações.
- Controles de acesso com sistemas de travamento, como portas com fechaduras, cartões de acesso físico, biometria.
- Monitoramento visual com câmeras de vigilância para monitorar e registrar atividades.
- Ambientes controlados em salas com acesso restrito a servidores e equipamentos críticos.

Os **controles lógicos** são medidos que protegem ativos de informação por meio de métodos computacionais, como software e configurações de sistema. Exemplificando esses controles, temos:

- **Autenticação de usuário:** senhas, autenticação de dois fatores, certificados digitais.
- **Firewalls e roteadores:** regulam o tráfego de dados na rede.
- **Controles de acesso a dados:** restrições baseadas em funções (RBAC), controle de acesso a bancos de dados.
- **Criptografia:** protege a confidencialidade dos dados durante a transmissão e armazenamento.

Na prática, uma abordagem eficaz de segurança da informação geralmente incorpora uma combinação de controles físicos e lógicos para proporcionar uma defesa abrangente contra uma variedade de ameaças.

Controles organizacionais, relacionados à segurança, continuidade do serviço

Esses controles referem-se a práticas e medidas implementadas pela organização como um todo para garantir a segurança da informação e a continuidade operacional, mesmo em face de eventos adversos. Esses controles são cruciais para garantir que a empresa possa enfrentar e se recuperar de incidentes de segurança, interrupções operacionais ou desastres. Dentre eles, podemos listar:

Políticas de segurança da informação que é a documentação formal que estabelece as diretrizes e expectativas da organização em relação à segurança da informação. Na auditoria fazemos a revisão das políticas para garantir que elas abordem aspectos, como classificação de dados, uso aceitável, responsabilidades dos usuários e a verificação da conformidade das práticas operacionais com as políticas estabelecidas.

Gestão de riscos é o processo contínuo de identificação, avaliação e mitigação de riscos de segurança da informação. Dentro da auditoria fazemos a avaliação dos processos de identificação e avaliação de riscos e a revisão das estratégias de mitigação e planos de resposta a incidentes.

O Plano de Continuidade de Negócios (BCP) e Plano de Recuperação de Desastres (DRP) são os documentos que detalham como a organização continuará suas operações em caso de interrupções significativas ou desastres. Em uma auditoria, fazemos a verificação da existência e atualização dos planos e o teste e avaliação periódicos dos planos para garantir a eficácia

Treinamento e conscientização são os programas para educar os funcionários sobre práticas seguras e conscientizá-los sobre ameaças de segurança. Na auditoria podemos fazer a revisão dos programas de treinamento de segurança e a avaliação da eficácia dos programas na conscientização e adesão dos funcionários.

Governança de segurança da informação é a estrutura de governança que define papéis, responsabilidades e processos para garantir a segurança da informação em toda a organização. Em uma auditoria, podemos fazer a verificação da estrutura de governança e suas interações com as áreas de negócios e a avaliação da comunicação efetiva das políticas de segurança e práticas.

COBIT é um framework para governança de TI que possui um conjunto de controles mais amplos, que podem ser implantados, incluindo os de segurança e privacidade. Já o ITIL é um conjunto de melhores práticas para o gerenciamento de serviços e estabelece também um conjunto de controles mais amplos que inclui aspectos de segurança.

